AegisBank 银行 AI 智能体安全自评报告

2026 深圳国际金融科技大赛 人工智能赛道

队伍 0xChainAegis 版本日期 2026 年 10 月 25 日

本报告说明 AegisBank 如何限制操作权限、绑定人工确认、记录审计与处理异常，并列明演示原型的已知风险。评估对象是本地 Mock Bank Core 原型，结论不是生产安全认证、合规审计或渗透测试证明。

1 评估范围与威胁边界

系统分离语言理解与金融授权：Planner 只提出计划，确定性编译器、风险引擎、网关与执行器控制执行。账户、交易、卡片、订阅和理财事实来自 SQLite，没有真实银行、支付网络、真实客户或商户订单接入。

对象	主要威胁	当前控制
指令和模型候选	注入 越权 幻觉 条件遗漏	注入检查 候选白名单 Schema 与澄清
计划和确认	确认后改参 过期 重放	plan_hash Envelope nonce 有效期
工具和资金状态	越权 重复扣款 部分失败	统一网关 幂等 补偿与对账
审计和恢复	日志缺失 篡改 错误重试	journal SHA-256 链 UNKNOWN
服务与资源	依赖故障 可疑操作 工具失控	readiness 熔断 进程内沙箱

信任边界位于用户渠道、Planner 输出、授权执行和持久化事实之间。前端展示和本地存储不是授权来源，修改浏览器状态不能替代后端校验。角色由演示请求头自报，因此当前能力校验只能展示策略流程，不能证明真实调用者身份。

自评依据为当前代码、已有测试和本轮验证记录。没有开展完整外部渗透测试或生产环境验证。所有“已实现”均限定于本地原型；测试通过只代表对应条件下可复现。

代码依据 main.py；gateway.py；executor.py；planning/；trust/；banking/repository.py。代码路径相对 backend/aegisbank_api/，前端另注。

2 权限分级的实现

2 1 后端角色能力

能力	user	operator	auditor
tool:execute 银行业务工具	允许	拒绝	拒绝
permission:manage 工具授权	允许	允许	拒绝
audit:read 读取审计	允许	允许	允许
ops:manage 运维和熔断解除	拒绝	允许	拒绝
trust:inspect 信任核查	允许	允许	允许

AuthzService 是矩阵唯一来源。网关检查角色能力与工具最小权限；operator 可以运维和权限管理，但不能代替用户发起银行操作。前端从 /authz/me 取得能力，仅做入口禁用与说明；策略加载失败关闭写入口。

2 2 风险和确认强度

级别	执行策略	示例
绿色	满足权限后自动执行	余额 账单 产品 订阅等只读查询
黄色	明确确认操作对象和参数	小额转账且预计日累计≤1000 元 取消订阅
红色	确认加演示 MFA	预计日累计>1000 元 挂失 改密码 理财申购

DynamicRiskEngine 只保持或上调工具基线风险。单笔转账超过 5000 元同样触发红色；其他操作按各自规则。确认执行前复检事实，等待期间的累计金额、参数、权限或风险改变不能沿用旧授权。

演示 OTP 为 246810，模拟生物识别 token 为 FACE-888888，均为固定演示值，不连接真实短信、人脸识别或设备身份。验证成功只能说明演示链路工作，不能证明生产核身能力。

代码依据 trust/authz.py；risk.py；gateway.py；trust/mfa.py；extensions/mfa.py；frontend/src/roles.ts。

3 确认完整性与防重复执行

3 1 ActionEnvelope 绑定

每个待确认步骤保存 user_id、plan_hash、step_id、tool_name、arguments_hash、risk_level、permission、nonce、签发时间和到期时间。服务端重新生成关键值并比对后才执行，默认确认有效期 300 秒。nonce 一次性消费，审批令牌不作为真实授权凭据对外暴露。

关键事件	响应语义	下一步
计划 参数 风险 权限变化	409 拒绝旧确认	检查原因 重新发起
过期或 nonce 重放	409 拒绝	生成新有效计划
MFA 错误或能力不足	403 拒绝	核对验证方式和权限
服务未就绪	503 关闭写入	恢复依赖后再试
原请求仍在处理	409 处理中	保留原请求 查询结果

3 2 幂等与结果未知

发起和确认使用 Idempotency-Key，同一逻辑提交复用原键，内容变化不能沿用。IM message_id 对重复投递回放原回执。断线保留原请求内容和键，先查询结果；不能因连接失败认定未执行，也不能自动用新键重试写操作。

前端恢复快照仅定位任务，继续处理前向服务端核对计划和风险。非 JSON HTTP 错误保留状态，避免明确拒绝被误解为网络结果未知。失败回执要求核对步骤和账户，不推断余额保持不变。

3 3 对语义不确定性的控制

金额规范化覆盖已支持的千分位和中文金额；不支持的格式、条件和组合转澄清。限定表达与预置组合不等于通用语义理解。编译与人工确认不能单独证明完整保留用户意图，用户仍需检查对象、金额和步骤。

代码依据 trust/action_envelope.py；trust/idempotency.py；trust/clarification.py；scheduler.py；planning/llm.py；frontend/src/api.ts；session.ts。

4 执行防护与故障恢复

4 1 受控入口与 readiness

所有工具经 gateway.py 与 ToolExecutor，不直接调用工具体。readiness 检查 SQLite、审计链、种子和 Planner，未就绪写接口返回 503，前端关闭写入口。界面禁用只改善体验，后端必须独立拒绝。

4 2 注入熔断与沙箱

注入命中整条请求拒绝，不能留下部分节点继续执行。连续失败、短时多次红色任务和累计注入命中共用熔断状态，打开时拒绝写操作；恢复由冷却或具备 ops:manage 的操作员审计解锁。当前是系统级计数，没有按租户和用户隔离。

进程内 ExecutionGuard 提供工具白名单、参数和输出体积、网络与墙钟超时约束。默认输入上限 8192 字节、输出上限 64000 字节、超时 5 秒，可配置。违规先审计后拒绝。Python 线程不能强杀，底层扩展或子进程可能绕过 socket 拦截，不能宣称 OS 级隔离。

4 3 证据与哈希链

审计记录时间、指令、DAG 路径、参数、结果、确认、风险和分层证据。规范 JSON 与前一条哈希共同计算 SHA-256；/api/audit/verify 重算链并返回 valid 与 checked。链校验只验证当前存储的一致性；没有外部可信锚点，不能宣称抵御管理员整链重写。

4 4 暂停补偿和人工对账

暂停在节点之间生效，不能强制中止正在运行的工具。回退按 journal 逆序调用登记补偿，仍需权限与风险复检。不可逆步骤或补偿失败转 UNKNOWN，禁止自动重复执行。RECONCILED 是核查结论记录，ROLLED_BACK 是补偿链完成，两者都要结合步骤和业务事实核对。

代码依据 trust/readiness.py；trust/circuit_breaker.py；trust/sandbox.py；audit.py；trust/pause.py；scheduler.py；extensions/compensation.py。

5 已知风险与后续措施

等级按真实客户和资金接入前的影响判断。P0 为生产前必须解决，P1 需要独立控制与验证，P2 为治理或可用性完善项。已有缓解仅适用于本地演示。

风险和等级	当前情况	上线前措施
身份缺失 P0	自报角色 固定 demo-user	真实认证 会话和租户隔离
固定 MFA P0	固定 OTP 模拟 token 无真实核身	一次性挑战 真实 MFA 失败锁定
隔离不足 P1	进程内守卫 线程不可强杀	容器 资源与文件隔离
语义覆盖有限 P1	条件组合保守澄清 缺通用上下文	语义契约 来源检查 独立评测
SQLite 单机 P1	事务和 readiness 无高可用	高可用数据库 备份恢复
系统级熔断 P1	计数共享 可能影响其他操作	按用户租户隔离和限流
IM 未绑定 P1	无平台签名 无真实用户映射	签名校验 OAuth 用户绑定
审计无外部锚 P1	本地链只验内部一致性	独立权限 WORM 外部锚点
记录增长 P2	幂等和 nonce 缺 TTL 清理	过期归档 容量监控
补偿有限 P2	仅登记工具可回退	补偿规格 对账手册 失败演练
浏览器覆盖 P2	单元测试不能代表全部体验	网络时序 无障碍 多浏览器回归

生产网络还需 HTTPS、网关限流、安全响应头、密钥管理、依赖扫描和监控告警。默认本机部署不能直接用作公开银行服务。真实接口接入前应由业务、风控、安全和合规人员共同审查。

代码依据 config.py；trust/；channels/im.py；docs/SECURITY.md；docs/ROADMAP.md；deliverables/05-安全自评报告.md。

6 验收方法与自评结论

对象	测试或入口	必须观察到的结果
角色和撤权	test_authz.py 和安全回归	无能力或撤权后不执行
确认绑定	test_trust.py	改参 过期 重放拒绝
MFA	test_mfa.py	错误验证留痕 不执行
语义和注入	test_planner.py test_nlp_safety.py	拒绝或澄清 无遗漏条件写计划
熔断沙箱	test_breaker.py test_sandbox.py	打开后拒绝 违规有审计
补偿和未知	test_compensation.py	不可逆或失败转人工
请求与界面	frontend/src/*.test.* 浏览器检查	拒绝 未知 成功分别呈现

6 1 复跑与演示前检查

backend 执行 uv run pytest；frontend 执行 pnpm test 和 pnpm build；六场景可运行 scripts/scenario-check.py；审计使用 GET /api/audit/verify。测试临时库与演示库隔离。当前实际结果见随附本轮验收记录，历史测试数字不作为当前结论。

演示前确认 ready、当前角色和工具授权，使用新模拟库依次展示绿色、黄色与红色。错误 MFA 和用户拒绝必须不执行。保留任务标识核对审计；出现 UNKNOWN 时停止重复提交并人工核查；熔断通过运维入口处理，不删除日志或改库绕过。

6 2 自评结论

原型已建立从意图到受控执行的权限分级、确认绑定、幂等、审计与异常恢复链路，适合本地模拟场景展示。真实身份、生产 MFA、OS 沙箱、高可用和独立审计存储尚未完成，不得把演示能力表述为生产安全能力。

新增工具、修改规则或接入真实系统时，应复审授权、参数来源、不可逆性、幂等与审计。自动化通过不能替代真实环境的独立验证。

代码依据 backend/tests/；frontend/src/*.test.*；scripts/scenario-check.py；docs/SECURITY.md。